Study Guide SC-300 — Identity and Access Administrator

> **Language:** English | Nederlands

Duration: 7 weeks · **Lab preset:** Standard (DC01 · MGMT01 · W11-01 · W11-02) **MS Learn path:** Identity and Access Administrator **Exam weight:**

Domain	Weight
Implement and manage user identities	20–25%
Implement authentication and access management	25–30%
Plan and implement workload identities	20–25%
Plan and automate identity governance	20–25%

> **Updated:** Skills measured as of November 7, 2025. Domains renamed and reweighted. "Implement access management for Azure resources by using Azure roles" was **removed** from the exam. **Global Secure Access** added as a new section under authentication and access management.

> **Prerequisite:** Microsoft 365 E5 developer tenant + Azure subscription (MSDN) SC-300 involves more Azure portal work than MD-102/MS-102 **Tenant note:** use the local VMs for hybrid identity and the shared dev tenant for Entra, governance, and portal work. Whenever an exercise mentions tenant policy or Entra portal steps, that part belongs in the tenant.

> **New as of November 2025:** *Implement Global Secure Access* was added to the exam. Current SSW-Lab scripts do not yet cover this area end-to-end, so use the matching MS Learn module as a required companion.

How to use this study guide

- Read the exam domain and learning objectives first each week; SC-300 is heavily about choosing between similar identity options with different trade-offs.
- Then perform the lab exercises in Entra, Azure, and on the on-premises VMs where relevant so you can observe hybrid behaviour rather than only reading about it.
- Complete the knowledge check only after the theory and lab work, and pay close attention to why the rejected options are wrong.

- If you work with bilingual colleagues, keep Microsoft terminology active in both languages, such as *guest user / gastgebruiker* and *workload identity / workload-identiteit*.

Lab coverage and expectations

- **Strong SSW-Lab coverage:** hybrid identity, Entra Connect, PHS/PTA, SSPR, Conditional Access, PIM, app registrations, service principals, and identity governance fundamentals.
- **Partial coverage:** lifecycle workflows, access reviews at scale, workload identities in more complex application chains, and some risk detections depend on tenant licensing and suitable test signals.
- **Study separately as well:** Global Secure Access, some of the newest Entra portal experiences, and scenarios that require a second tenant or production-like partner trust.
- Use the lab steps to build understanding, but always test yourself on the design decision too: when should you choose a specific identity model, policy, or governance approach?

How to use the knowledge checks

- Answer first which design or control you would choose, and only then how you would implement it technically.
- For every answer, state which risk is reduced or which governance problem is being solved.
- Revisit missed questions with a terminology focus: many SC-300 choices sound similar, but their prerequisites are different.
- Spend extra attention on guest access, Conditional Access, workload identities, and governance because they generate many scenario-style exam questions.

Week 1 — Entra ID fundamentals and hybrid identity

> **Exam domain:** Implement and manage user identities · **Weight:** 20–25%

> **Real-world scenario:** A mid-sized manufacturing company has 800 on-premises Active Directory users and is migrating to Microsoft 365. The IT consultant must decide which hybrid authentication method to deploy so that users can sign in to Microsoft 365 services with their existing AD credentials — without storing password hashes in the cloud, as required by the company's security policy. At the same time, SSPR must be configured so employees can reset their own passwords from the login screen without calling the helpdesk.

Learning Objectives

- [ ] Configure and manage an Entra ID tenant, including tenant properties and user settings
- [ ] Create, configure, and manage user and group objects in Entra ID
- [ ] Implement and verify Azure AD Connect Sync with Password Hash Synchronization (PHS)
- [ ] Configure Seamless SSO and understand the underlying Kerberos mechanism

- [ ] Distinguish between Entra Connect Sync and Entra Cloud Sync and select the appropriate option
- [ ] Manage the user lifecycle including soft delete, restore, and hard delete behaviour

MS Learn modules

- Implement initial configuration of Microsoft Entra ID
- Create, configure, and manage identities
- Implement and manage hybrid identity

Lab exercises (SSW-Lab)

VM	Task
LAB-DC01	Verify AD structure: `Get-ADForest`, `Get-ADDomain`, `Get-ADUser -Filter *`
LAB-DC01	Install Azure AD Connect Sync → configure *Password Hash Sync*
LAB-DC01	Verify sync: `Start-ADSyncSyncCycle -PolicyType Delta`
LAB-MGMT01	Open **Entra admin center** (entra.microsoft.com) → verify sync status
LAB-MGMT01	Configure *Custom Security Attributes* for user classification
LAB-MGMT01	Review *Audit logs* in Entra ID → filter on user creation events

Lab commands

```
# Trigger a delta sync cycle from the AD Connect server
Start-ADSyncSyncCycle -PolicyType Delta

# View sync connector status
Get-ADSyncConnector | Select-Object Name, ConnectorTypeName, LastSyncTime

# Restore a soft-deleted user via Microsoft Graph PowerShell
Restore-MgDirectoryDeletedItem -DirectoryObjectId "<object-id>"

# Force a full sync cycle (use sparingly)
Start-ADSyncSyncCycle -PolicyType Initial
```

Key Concepts

Term	Description
Entra Connect Sync	On-premises sync agent that replicates AD objects to Entra ID; supports complex filtering, attribute writeback, and device writeback
Entra Cloud Sync	Lightweight, cloud-managed provisioning agent — ideal for simple multi-forest scenarios; fewer features than full Connect Sync

Term	Description
Password Hash Sync (PHS)	Synchronized hashed password hashes to Entra ID; authentication occurs in the cloud — remains functional even if on-prem AD is unreachable
Pass-through Authentication (PTA)	Authentication is validated by an on-premises agent; no password hashes stored in the cloud — requires the PTA agent to be online
Seamless SSO	Domain-joined Windows devices authenticate to Entra ID apps automatically via Kerberos, using the `AZUREADSSOACC` computer account in AD
Soft delete	User account is deactivated and retained for 30 days; restorable via Entra portal or PowerShell
Hard delete	Permanent removal of a user object after the 30-day soft-delete window; cannot be undone
Staging mode	Entra Connect calculates sync operations but does not apply changes — used for testing or standby failover configurations

Knowledge check

1. What are the three authentication methods in hybrid identity and when do you use each?
2. How does *Seamless SSO* work and which Kerberos component is involved?
3. What is the difference between *soft delete* and *hard delete* of an Entra ID user?
4. How do you configure *password writeback* and why is it needed for SSPR?

▶ Answers

Week 2 — External identities and Entra B2B

> **Exam domain:** Implement and manage user identities · **Weight:** 20–25%

> **Real-world scenario:** A Sogeti consultant is helping a financial services firm onboard three strategic partners who need access to a shared SharePoint site and a Teams workspace for project collaboration. The security team requires that partner users authenticate using their own corporate credentials, not a shared account, and that MFA claims from a trusted partner tenant are honoured to avoid double authentication challenges. Additionally, the CISO wants any user account flagged as high-risk by Identity Protection to be immediately blocked until remediated, without requiring manual admin intervention.

Learning Objectives

- ☐ Invite and manage B2B guest users and understand the redemption flow
- ☐ Configure cross-tenant access settings (inbound and outbound trust policies)

- ☐ Understand the difference between B2B collaboration and B2B direct connect
- ☐ Enable and configure Entra ID Protection risk policies
- ☐ Differentiate between user risk and sign-in risk, and apply appropriate remediation
- ☐ Simulate risky sign-ins in a lab environment to validate policy enforcement

MS Learn modules

- Implement and manage external identities
- Implement and manage Microsoft Entra ID Protection

Lab exercises (SSW-Lab)

VM	Task
LAB-MGMT01	Invite an external B2B user (use a personal or second tenant account)
LAB-MGMT01	Configure *Cross-tenant access settings*: block inbound access for specific tenants
LAB-MGMT01	Enable *Entra ID Protection* → review the *Risk detections* dashboard
LAB-MGMT01	Configure *User risk policy*: high risk → force password change
LAB-MGMT01	Configure *Sign-in risk policy*: medium risk → require MFA
LAB-W11-01	Simulate a risky sign-in: sign in as TestUser01 from an anonymous browser session

Lab commands

```
# Invite a B2B guest user via Microsoft Graph PowerShell
New-MgInvitation -InvitedUserEmailAddress "partner@contoso.com" `
    -InviteRedirectUrl "https://myapps.microsoft.com" `
    -SendInvitationMessage:$true

# List all guest users in the tenant
Get-MgUser -Filter "userType eq 'Guest'" | Select-Object DisplayName, Mail,
UserPrincipalName

# Dismiss a user risk (mark as false positive)
Invoke-MgDismissRiskyUser -UserIds "<user-object-id>"

# Confirm user compromise (triggers further protective actions)
Invoke-MgConfirmRiskyUserCompromised -UserIds "<user-object-id>"
```

Key Concepts

Term	Description
B2B Collaboration	External users are invited as guest accounts in your tenant; objects appear in your directory with `#EXT#` in the UPN
B2B Direct Connect	A mutual trust relationship between two tenants that allows access to specific resources (e.g., Teams shared channels) without creating guest objects in either directory
Cross-tenant synchronisation	Automatically provisions user objects from one Entra tenant into another as internal (non-guest) users, based on a synchronisation configuration
Redemption flow	The process by which an invited guest accepts the invitation, verifies their identity, and is granted access to the inviting tenant's resources
One-time passcode (OTP)	A fallback authentication method for guest users who have no Azure AD, Microsoft, or Google account — a temporary code is sent by email
Sign-in risk	The probability that a specific authentication attempt was not made by the legitimate user (e.g., sign-in from anonymous IP, atypical travel)
User risk	The cumulative probability that a user account has been compromised (e.g., leaked credentials detected on the dark web)
Dismiss risk	An admin action that marks a detected risk as a false positive and clears the risk state without taking further action

Knowledge check

1. What is the difference between *B2B direct connect* and *B2B collaboration*?
2. How does *Identity Protection* work — what signals does it use for risk scores?
3. What is a *risky user* versus a *risky sign-in*? How do you remediate each?
4. What does a *Conditional Access policy based on user risk* do?

▶ Answers

Week 3 — Authentication methods and MFA

> **Exam domain:** Implement authentication and access management · **Weight:** 25–30%

> **Real-world scenario:** A government agency client is requiring Sogeti to implement phishing-resistant MFA for all 2,500 employees as part of a Zero Trust compliance mandate. The helpdesk currently handles 40–50 password reset calls per week. The IAM consultant must design an authentication strategy that replaces SMS-based MFA with FIDO2 security keys for privileged users,

> deploys Microsoft Authenticator with passkeys for regular staff, and introduces a Temporary Access Pass process for new-joiner onboarding and lost-device recovery — all managed from a single policy location rather than the legacy per-user MFA portal.

Learning Objectives

- [ ] Configure and manage authentication methods in the tenant-wide Authentication methods policy
- [ ] Understand and explain phishing-resistant MFA methods and their distinctions
- [ ] Enable and test passwordless authentication with FIDO2 and Microsoft Authenticator
- [ ] Configure Windows Hello for Business in a hybrid environment
- [ ] Issue and use a Temporary Access Pass (TAP) for onboarding and recovery scenarios
- [ ] Migrate from legacy per-user MFA settings to Conditional Access-managed MFA

MS Learn modules

- Plan and implement multifactor authentication
- Implement passwordless authentication
- Manage user authentication

Lab exercises (SSW-Lab)

VM	Task
LAB-MGMT01	Open **Entra** → **Security** → **Authentication methods** → enable FIDO2 and Authenticator
LAB-W11-01	Register *Microsoft Authenticator* as MFA method for TestUser01
LAB-W11-01	Register *Windows Hello for Business* on W11-01
LAB-MGMT01	Configure *Authentication strength* in Conditional Access: Phishing-resistant MFA
LAB-MGMT01	Review the *Authentication methods activity* report → analyse method usage
LAB-MGMT01	Disable *legacy per-user MFA* → migrate to Conditional Access-based MFA

Lab commands

```
# Create a Temporary Access Pass for a user
New-MgUserAuthenticationTemporaryAccessPassMethod -UserId "<user-id>" `
    -LifetimeInMinutes 60 -IsUsableOnce:$true

# List registered authentication methods for a user
Get-MgUserAuthenticationMethod -UserId "<user-id>"

# Remove a specific authentication method (e.g., a lost FIDO2 key)
Remove-MgUserAuthenticationFido2Method -UserId "<user-id>" `
    -Fido2AuthenticationMethodId "<method-id>"

# Report on authentication method registrations across the tenant
Get-MgReportAuthenticationMethodUserRegistrationDetail |
    Select-Object UserPrincipalName, IsMfaRegistered, IsPasswordlessCapable
```

Key Concepts

Term	Description
FIDO2 security key	A hardware token (e.g., YubiKey) that performs cryptographic authentication — phishing-resistant because the key is bound to the specific origin domain
Microsoft Authenticator (passwordless)	Push notification or number-matching sign-in via the Authenticator app; phishing-resistant via number matching — no password is entered
Passkey	A FIDO2-based credential stored in the Microsoft Authenticator app or a compatible platform authenticator; combines the convenience of the app with hardware-level security
Temporary Access Pass (TAP)	A time-limited, one-time or multi-use passcode used for initial onboarding, MFA method re-registration, or account recovery when other methods are unavailable
Authentication strength	A Conditional Access grant control that requires users to authenticate with a specific set of methods (e.g., Phishing-resistant MFA); can be built-in or custom
Certificate-based authentication (CBA)	Uses an X.509 certificate stored on a smart card or device as the primary authentication factor; phishing-resistant
Entra Password Protection	Blocks weak and commonly used passwords via a global banned list plus a custom tenant-specific banned list; can be deployed on-premises via a DC agent
Combined security info registration	A unified registration experience where users set up both MFA methods and SSPR recovery methods in a single workflow

Knowledge check

1. What is *phishing-resistant MFA* and which methods qualify?

2. How does *Windows Hello for Business* work in a hybrid environment?
3. What is the difference between the *Authentication methods policy* and *legacy MFA settings*?
4. When do you use a *Temporary Access Pass (TAP)*?

▶ Answers

Week 4 — Conditional Access and Global Secure Access

> **Exam domain:** Implement authentication and access management · **Weight:** 25–30%

> **Real-world scenario:** A Sogeti team is engaged by a law firm with 350 users, strict data residency requirements, and a large remote workforce. The firm wants to ensure that no unmanaged or non-compliant device can access SharePoint and Teams, that access from outside the EU triggers step-up authentication, and that a senior partner approval is required every time an admin disables a Conditional Access policy. Additionally, the firm is evaluating replacing its legacy VPN with a zero-trust per-application access model so that remote staff can only reach the applications they need, not the full internal network.

Learning Objectives

- ☐ Design and implement Conditional Access policies using the signals-decisions-enforcement model
- ☐ Use the What If tool to validate CA policy behaviour before enabling
- ☐ Configure Named Locations, Authentication contexts, and Protected actions
- ☐ Understand Continuous Access Evaluation (CAE) and its advantages over standard token lifetimes
- ☐ Explain the three Global Secure Access traffic profiles and their use cases
- ☐ Differentiate between Global Secure Access Private Access and a traditional VPN

MS Learn modules

- Plan, implement, and administer Conditional Access
- Implement Conditional Access for cloud app access
- Implement Global Secure Access

Lab exercises (SSW-Lab)

VM	Task
LAB-MGMT01	Create CA policy: block access to all apps from non-compliant devices

VM	Task
LAB-MGMT01	Create CA policy: MFA required for admin roles on every sign-in
LAB-MGMT01	Use the *What If* tool in CA to simulate access decisions
LAB-W11-01	Test CA policy as TestUser01 → verify which controls are enforced
LAB-W11-02	Test with a non-enrolled device → verify block
LAB-MGMT01	Enable *Sign-in frequency* for sensitive applications (re-auth every 4 hours)
LAB-MGMT01	Review the **CA insights and reporting** workbook in Entra ID
LAB-MGMT01	In the Entra admin center, explore **Global Secure Access**: review Private Access and Internet Access settings
LAB-MGMT01	Enable *Internet Access for Microsoft 365* in Global Secure Access → review traffic logs

Lab commands

```
# List all Conditional Access policies and their state
Get-MgIdentityConditionalAccessPolicy |
    Select-Object DisplayName, State, CreatedDateTime

# Retrieve sign-in logs filtered to CA policy failures (requires Log Analytics or
MS Graph)
# Via Microsoft Graph PowerShell:
Get-MgAuditLogSignIn -Filter "conditionalAccessStatus eq 'failure'" -Top 20 |
    Select-Object UserPrincipalName, AppDisplayName, ConditionalAccessStatus

# Get all named locations
Get-MgIdentityConditionalAccessNamedLocation | Select-Object DisplayName, Id

# Enable or update a CA policy state
(enabled/disabled/enabledForReportingButNotEnforced)
Update-MgIdentityConditionalAccessPolicy -ConditionalAccessPolicyId "<policy-id>"
`
    -State "enabledForReportingButNotEnforced"
```

Key Concepts

Term	Description
CA Signals	The inputs evaluated by the policy engine: user/group/role, target application, network location, device platform and compliance state, client app type, sign-in risk, and user risk
Grant control	CA decision that either blocks access or grants it subject to conditions (MFA, compliant device, authentication strength, terms of use)
Session control	CA decision that allows access but restricts the session (sign-in frequency, persistent browser session, app-enforced restrictions, continuous access evaluation)
Named location	An IP range or country/region list marked as trusted or untrusted, used as a CA signal for location-based policies
Continuous Access Evaluation (CAE)	Tokens are revoked in near-real-time when a risk event occurs (e.g., admin revokes session, password change, location change), closing the gap left by standard token lifetimes (60–90 min)
Authentication context	A tag assigned to a CA policy and consumed by an application to trigger step-up authentication when a specific high-risk action is performed within the app
Protected actions	High-privilege Entra ID operations (e.g., disabling a CA policy, assigning a privileged role) that always require additional CA verification via an assigned authentication context
Global Secure Access (GSA)	Microsoft's Security Service Edge (SSE) solution, integrating Zero Trust Network Access (ZTNA) and a Secure Web Gateway into the Entra ID control plane
Private Access	The GSA ZTNA component — provides identity-aware, per-application access to on-premises and private resources without requiring a traditional VPN tunnel
Internet Access	The GSA Secure Web Gateway component — filters and secures internet-bound traffic from devices running the GSA client
Universal Conditional Access	CA policy enforcement at the network level via the GSA infrastructure, extending policy control beyond the authentication moment to the ongoing network session

Knowledge check

1. What is the difference between *Block* and *Grant with MFA* in Conditional Access?
2. How do *Named Locations* work and when do you use *compliant network*?
3. What are *Authentication contexts* and when do you use them?
4. How do you prevent *lock-out* during CA migration in production?
5. What is *Global Secure Access* and what are the three traffic profiles (Private, Internet, M365)?
6. What is the difference between *Private Access* and a traditional VPN?

▶ Answers

Week 5 — Application access and app registrations

> **Exam domain:** Plan and implement workload identities · **Weight:** 20–25%

> **Real-world scenario:** A Sogeti DevOps team is building an internal automation platform for a banking client. The platform uses an Azure Function to read emails from a shared mailbox via Microsoft Graph, write results to SharePoint, and call an internal REST API. The security team requires that the Azure Function never uses a stored password or client secret — only a managed identity — and that the internal API uses app-only permissions with explicit admin consent. A separate concern is that 12 third-party SaaS apps in the tenant have been granted overly broad API permissions by individual developers, and those need to be reviewed and tightened.

Learning Objectives

- ☐ Distinguish between an App registration and an Enterprise application, and explain when each is used
- ☐ Configure API permissions (delegated and application) and understand the impact of admin consent
- ☐ Implement OAuth 2.0 and OpenID Connect flows for application authentication
- ☐ Create and manage client secrets and certificates for app authentication
- ☐ Configure Entra Application Proxy for secure access to on-premises web applications
- ☐ Understand managed identities (system-assigned vs. user-assigned) and when to use each

MS Learn modules

- Manage and implement application access in Azure AD
- Implement app registrations
- Integrate single sign-on in Microsoft Entra ID

Lab exercises (SSW-Lab)

VM	Task
LAB-MGMT01	Register a test app in **Entra** → **App registrations**
LAB-MGMT01	Add *API permissions*: `User.Read` and `Mail.Read` → grant admin consent
LAB-MGMT01	Create a *client secret* → note the value
LAB-MGMT01	Configure SSO for a gallery app (e.g. GitHub) via *Enterprise applications*
LAB-MGMT01	Configure *App proxy* for an on-premises app (use MGMT01 as test server)
LAB-MGMT01	Assign the app to a group → verify access in the *My Apps* portal

Lab commands

```
# List all app registrations in the tenant
Get-MgApplication | Select-Object DisplayName, AppId, CreatedDateTime

# List API permissions for a specific app registration
Get-MgApplicationRequiredResourceAccess -ApplicationId "<app-object-id>"

# Create a new client secret for an app registration
Add-MgApplicationPassword -ApplicationId "<app-object-id>" `
    -PasswordCredential @{ DisplayName = "LabSecret"; EndDateTime = "2026-01-01"
}

# List all enterprise applications (service principals) with app permissions
Get-MgServicePrincipal -Filter "servicePrincipalType eq 'Application'" |
    Select-Object DisplayName, AppId, AppRoles
```

Key Concepts

Term	Description
App registration	The developer-facing configuration object in Entra ID that defines the application's identity, OAuth/OIDC settings, redirect URIs, and API permissions
Enterprise application	The service principal instance of an application in your tenant — this is where you configure user/group assignments, SSO settings, and user provisioning (SCIM)
Delegated permission	The application acts on behalf of a signed-in user — the effective permissions are the intersection of the app's requested permissions and the user's own permissions
Application permission	The application acts as itself (as a background service or daemon) without a signed-in user — always requires admin consent; the app receives the full permissions granted
Managed identity	An Azure-native identity for Azure resources that is automatically managed by the platform — no credentials to store, rotate, or protect; eliminates secrets in code
System-assigned managed identity	Lifecycle is tied to the Azure resource — automatically deleted when the resource is deleted; one-to-one relationship
User-assigned managed identity	An independent identity object that can be assigned to multiple resources; lifecycle is managed separately from any individual resource
Entra Application Proxy	Publishes on-premises web applications securely via Entra ID using an outbound-only connector — no inbound firewall ports required
SCIM provisioning	Automated user and group provisioning to SaaS applications using the System for Cross-domain Identity Management open standard

Knowledge check

1. What is the difference between an *App registration* and an *Enterprise application*?
2. How does the OAuth 2.0 *authorization code flow* work in summary?
3. What is a *managed identity* and when do you use system-assigned versus user-assigned?
4. What does *application proxy* do and which ports does it require?

▶ Answers

Week 6 — Identity governance: Entitlement and Access Reviews

> **Exam domain:** Plan and automate identity governance · **Weight:** 20–25%

> **Real-world scenario:** A Sogeti consultant is designing an identity governance framework for a healthcare organisation with 3,000 employees and strict regulatory requirements (NEN 7510, ISO 27001). Doctors, nurses, and administrative staff require different access packages that expire automatically when a project ends. The compliance team has mandated quarterly access reviews for all privileged roles, and the HR system must automatically trigger account deactivation and access revocation within 24 hours of an employee's recorded departure date. PIM must be enabled for all Global Administrator roles, with a two-person approval workflow and MFA on every activation.

Learning Objectives

- ☐ Create and manage entitlement management catalogs and access packages with approval workflows
- ☐ Configure access package lifecycle settings including expiration, renewal, and separation of duties
- ☐ Create and manage access reviews for groups, applications, and privileged roles
- ☐ Enable and configure Privileged Identity Management (PIM) for Entra ID roles
- ☐ Activate a PIM-eligible role Just-in-Time and review the audit trail
- ☐ Explain lifecycle workflows in Entra ID Governance and their use cases

MS Learn modules

- Plan and implement entitlement management
- Plan, implement, and manage access reviews
- Implement Privileged Identity Management

Lab exercises (SSW-Lab)

VM	Task
LAB-MGMT01	Create an *Access package* via **Entra** → **Identity Governance** → **Entitlement management**
LAB-MGMT01	Configure *policy*: users can self-request access, manager must approve
LAB-W11-01	Request the Access package as TestUser01 via the *My Access* portal (`myaccess.microsoft.com`)
LAB-MGMT01	Approve the request → verify the assignment
LAB-MGMT01	Create an *Access review* for a group → assign a reviewer
LAB-MGMT01	Enable **Privileged Identity Management (PIM)** for the *Global Administrator* role
LAB-MGMT01	Activate the GA role *Just-in-time* via PIM → verify audit trail

Lab commands

```
# List all PIM eligible role assignments
Get-MgRoleManagementDirectoryRoleEligibilitySchedule |
    Select-Object PrincipalId, RoleDefinitionId, Status

# Retrieve PIM activation history (audit)
Get-MgRoleManagementDirectoryRoleAssignmentScheduleRequest |
    Select-Object PrincipalId, Action, Status, CreatedDateTime, Justification

# List all access packages in a catalog
Get-MgEntitlementManagementAccessPackage |
    Select-Object DisplayName, Id, CreatedDateTime

# Get pending access package assignment requests
Get-MgEntitlementManagementAssignmentRequest -Filter "state eq 'pendingApproval'"
|
    Select-Object Id, RequestType, State
```

Key Concepts

Term	Description
Entitlement management	The Entra ID Governance framework for managing access lifecycle via catalogs, access packages, and automated approval and expiry workflows
Catalog	A container in entitlement management that groups related resources (Entra groups, applications, SharePoint sites) for a specific organisational unit or project
Access package	A bundle of resources (from a catalog) that users can request together through a single structured workflow, with defined approval, duration, and review requirements
Separation of duties	A configuration in entitlement management that prevents a user from holding two incompatible access packages simultaneously — enforces least privilege
PIM — Eligible assignment	The user has been granted the right to activate the role but must explicitly activate it, providing a justification and (if configured) completing MFA and approval
PIM — Active assignment	The role is permanently active for the user; no activation step is required — used sparingly for break-glass or service accounts
PIM — Just-in-time access	The practice of activating a privileged role only for the duration needed for a task, reducing the persistent attack surface of standing privileges
Lifecycle workflow	An automated Entra ID Governance workflow triggered by HR events (joiner, mover, leaver) that executes tasks such as generating TAPs, adding users to groups, or disabling accounts
Access review	A periodic, structured review in which designated reviewers confirm whether users should retain access to groups, applications, or privileged roles

Knowledge check

1. What is the difference between *entitlement management* and *access reviews*?
2. How does PIM *Just-in-Time access* work and why is it better than permanent role assignment?
3. What are *lifecycle workflows* in Identity Governance?
4. How do you configure *separation of duties* via incompatible access packages?

▶ Answers

Week 7 — Exam preparation

Activities

- Review weak domains based on the official exam study guide
- Complete the **Microsoft Learn practice assessment** for SC-300: Practice assessment
- Revisit PIM configuration, CA What-If scenarios and entitlement management
- Create an overview of all Identity Protection risk types and remediation steps
- Schedule your exam via Pearson VUE

Exam focus areas

- **Domain weights changed:** user identities 20–25%, workload identities 20–25%, governance 20–25%
- **Global Secure Access** is a new exam section — know Private Access, Internet Access and M365 profiles
- Azure RBAC for resources ("Implement access management for Azure resources") was **removed** from SC-300 scope
- Conditional Access: *What If* scenarios, authentication strength, continuous access evaluation and protected actions
- PIM: know the difference between eligible, active and permanent assignments
- Identity governance: entitlement management vs. access reviews vs. lifecycle workflows
- B2B: cross-tenant access settings, cross-tenant synchronisation and external collaboration settings
- App registrations: delegated vs. application API permissions; managed identities (system vs. user-assigned)
- Identity monitoring: KQL queries in Log Analytics, Identity Secure Score

---

Exam Coverage Gaps and Must-Do Labs

The SSW-Lab 7-week programme covers all four SC-300 exam domains. The following topics receive lighter treatment in the lab exercises but carry significant exam weight based on the November 2025 study guide. Prioritise these before scheduling the exam.

Coverage gaps to address

Gap	Why it matters	Recommended action
Global Secure Access — client deployment	GSA is a new exam section (Nov 2025). The lab exercises cover portal exploration and traffic profile configuration, but do not include client installation and end-to-end testing.	Complete the MS Learn GSA module. In a personal Azure/M365 tenant, install the GSA Windows client, enable the M365 profile, and review traffic logs.
Cross-tenant synchronisation	The exam tests cross-tenant sync as a distinct capability from B2B invitations. The lab exercises cover B2B collaboration and cross-tenant access settings but not automated cross-tenant provisioning.	Configure cross-tenant synchronisation between two test tenants (use a developer tenant as the target). Verify that a source user appears as an internal user (not a guest) in the target tenant.
Identity monitoring: KQL and Log Analytics	Monitoring and diagnostics are examined in Domain 4. Writing basic KQL queries against `SigninLogs` and `AuditLogs` is a practical exam skill.	Connect Entra ID diagnostic settings to a Log Analytics workspace. Practice the following queries: high-risk sign-ins, failed MFA attempts, CA policy failures, PIM activations, and role assignment changes.

Gap	Why it matters	Recommended action
Lifecycle workflows (joiner/mover/leaver)	Lifecycle workflows are explicitly listed in the Nov 2025 governance domain. They are not covered in the lab exercises.	In the Entra portal, create a joiner workflow that generates a TAP and sends a welcome email. Trigger it manually against a test user.
Workload identity risk (Defender for Cloud Apps)	Workload identity risk management and Defender for Cloud Apps integration appear in Domain 3.	Review the Defender for Cloud Apps app governance section. Understand how OAuth app policies detect risky workload identities and how to revoke app consent.
Entra Password Protection on-premises	On-premises Password Protection deployment (DC agent) is a hybrid identity topic that may appear in authentication questions.	Review the DC agent installation concept and understand that it intercepts password change requests via the Netlogon service, checking against the global and custom banned lists.

Must-do labs for exam readiness

1. **Global Secure Access end-to-end:** enable the M365 traffic forwarding profile, install the GSA client on a test device, authenticate, and verify that session traffic appears in GSA traffic logs. Understand what Universal Conditional Access means in this context.
2. **Cross-tenant synchronisation:** configure synchronisation from one Entra tenant to another. Validate that the provisioned user appears as a member user (not a guest), and test what happens when the source user is deactivated.
3. **App registration with both permission types:** create an app registration with `User.Read` (delegated) and `Mail.ReadBasic.All` (application) permissions. Grant admin consent. Explain the difference in effective permissions and why application permissions always require admin consent.
4. **KQL identity queries:** write and run at least three queries in Log Analytics — one against `SigninLogs` (e.g., high-risk sign-ins last 7 days), one against `AuditLogs` (e.g., role assignments), and one for CA policy failures. Be able to interpret the output.
5. **PIM full cycle:** assign a user an eligible Global Administrator role with approval required and MFA on activation. Activate the role as that user, complete the approval flow, verify the audit trail, and confirm the role expires automatically.

Exit criteria before booking the exam

1. You can map every SC-300 exam domain to a concrete lab exercise or practical scenario from your own environment.
2. You have tested CA, Identity Protection, workload identity, Global Secure Access, and governance capabilities in a live tenant — not just read about them.
3. You can analyse a sign-in risk incident using Log Analytics KQL rather than relying solely on portal clicks.
4. You understand why Azure RBAC for resources is out of scope and can articulate what remains in scope for workload identities.
5. You have completed the MS Learn practice assessment and scored consistently above 80%.